

Privilegios SeBackup / SeRestore

Objetivos de aprendizaje

Identificar la superficie, explicar la causa, diseñar una confirmación mínima, interpretar evidencia y proponer una mitigación causal.

Prerrequisitos

Flujo source-transformación-validación-sink, parsers, permisos y metodología de hipótesis. Revisa los prerrequisitos declarados en los metadatos.

Fundamentos técnicos

SeBackupPrivilege permite leer cualquier fichero ignorando sus ACL (pensado para software de backup), y SeRestorePrivilege permite escribir cualquiera. Con SeBackup puedes copiar los hives SAM y SYSTEM del registro, llevartelos y extraer los hashes NTLM locales, incluido el del administrador. Caso concreto del winprivesc-modelo via privilegios de token.

El privilegio existe para que las herramientas de copia lean ficheros bloqueados, pero no distingue backup legítimo de robo: si lo tienes, saltas todos los permisos NTFS. El SAM contiene los hashes locales; con ellos, ntlm-pth te da administrator sin crackear.

Modelo mental

Entrada controlada -> transformaciones -> validación -> componente final
-> sink -> efecto observable -> decisión

El paso crítico es demostrar qué componente consume el valor y con qué identidad o privilegios.

Superficie de ataque

Cuando whoami /priv (enum-privesc-windows) muestra SeBackupPrivilege (habitual en el grupo Backup Operators).

Cómo identificarla

- whoami /priv lista SeBackupPrivilege / SeRestorePrivilege habilitado.
- Pertenece al grupo Backup Operators.

Preguntas que debo hacerme

- ¿Qué dato controlo exactamente y en qué formato viaja?
- ¿Qué transformaciones y normalizaciones ocurren antes del sink?
- ¿Qué identidad ejecuta la operación y qué permisos tiene?
- ¿Qué otra explicación produciría la misma señal?
- ¿Cuál es la prueba de menor riesgo que separa ambas explicaciones?

Prueba mínima

reg save de HKLM\SAM y HKLM\SYSTEM; si funciona sin error de acceso, el privilegio esta activo.

Evidencia esperada: Dos ficheros .hive generados sin error; tras secretdump, hashes NTLM locales incluido administrator.

Construcción progresiva del payload

1. Reproduce una entrada válida.
2. Aísla un único valor controlable.
3. Define la primitiva mínima indicada por la fuente.

4. Predice resultado y control negativo.
5. Aplica una sola adaptación cuando haya evidencia de restricción.
6. Confirma de forma reproducible antes de ampliar impacto.

Capa 1: prueba documentada

```
reg save HKLM\SAM sam.hive && reg save HKLM\SYSTEM system.hive
```

Objetivo y contexto: Con SeBackup puedes exportar los hives del registro que contienen los hashes locales (SAM) y la clave para descifrarlos (SYSTEM), saltando el bloqueo habitual.

Resultado esperado: Dos archivos .hive. Baja ambos a tu Kali; el siguiente paso es extraer los hashes con impacket-secretsdump usando SAM + SYSTEM.

Capa 2: prueba documentada

```
impacket-secretsdump -sam sam.hive -system system.hive LOCAL
```

Objetivo y contexto: Extrae los hashes NTLM locales combinando SAM y SYSTEM. Es el paso que convierte los hives robados en credenciales usables.

Resultado esperado: Líneas usuario:rid:lm:nt. El NT hash de Administrator -> ntlm-pth con evil-winrm/psexec para shell como admin sin crackear.

Anatomía de los payloads

La primera prueba es `reg save HKLM\SAM sam.hive && reg save HKLM\SYSTEM system.hive`. Separa sus delimitadores, operadores, opciones, operandos y variables; algunos elementos no estarán presentes según el contexto. Las comillas, barras y separadores pertenecen a una capa concreta. Usa la explicación de cada capa para determinar qué símbolo altera sintaxis y cuál transporta datos.

Variaciones según el contexto

No traslades una prueba entre sistemas operativos, motores, frameworks o versiones sin revisar sintaxis y comportamiento. Conserva la primitiva y vuelve a serializarla para el parser real.

Filtros y bypasses

No existe un bypass universal. Registra la forma enviada, la forma decodificada, la comparación, la normalización y la forma consumida. Una adaptación es válida solo si demuestra una discrepancia concreta; si la validación ocurre sobre la forma canónica y expresa la propiedad correcta, la variante no debe funcionar.

Evidencias de confirmación

Dos archivos .hive generados sin error; tras secretsdump, hashes NTLM locales incluido administrator.

Usa además una entrada inocua y un control negativo. No confundas reflexión, error genérico o demora aislada con confirmación.

Escalado de impacto

- Confirma SeBackup en `whoami /priv`.
- Copia los hives SAM y SYSTEM (via `reg save` o `robocopy /b`).
- Transfiérelos a tu Kali y extrae los hashes con `secretsdump`.
- Usa el hash NTLM de administrator con `ntlm-pth` para shell como admin.

Amplía únicamente dentro del laboratorio y cuando cada salto aporte una capacidad nueva demostrable.

Errores frecuentes

- `whoami /priv` no muestra esos privilegios habilitados.
- Ejecutar la prueba sin adaptar variables ni versión.

- Cambiar varias capas a la vez.
- Omitir el control negativo o no guardar evidencia.

Diagnóstico de payloads fallidos

Síntoma	Posible causa	Prueba de diagnóstico	Adaptación
Rechazo inmediato	Formato o precondition	Repetir entrada válida	Corregir transporte
Sin diferencia	Entrada ignorada o canal ciego	Marcador y control negativo	Buscar evidencia adecuada
Error del componente	Contexto o versión	Reducir a prueba mínima	Consultar manual detectado
Resultado parcial	Permisos/restricción	Comprobar identidad y alcance	Reducir primitiva

Mitigaciones

Eliminar el dato controlable del sink cuando sea posible; usar APIs estructuradas, allowlists sobre valores canónicos, privilegio mínimo, autorización en servidor y registros que permitan detectar abuso. La defensa concreta debe impedir la causa explicada en Fundamentos técnicos.

Relación con pentesting y certificaciones

Se espera reconocer la señal, justificar la prueba elegida, adaptar variables, interpretar salida y documentar impacto y mitigación. La puntuación debe premiar razonamiento y evidencia, no memoria literal.

Caso guiado

Parte de una señal de la lista anterior. Escribe observación e hipótesis, ejecuta la prueba mínima, compara con el control y clasifica el resultado como no confirmado, indicio o confirmación. Solo entonces sigue los pasos de escalado relevantes.

Caso de adaptación

Si la prueba básica falla, no cambies caracteres al azar. Comprueba primero transporte, parser, versión, permisos y canal de evidencia. Diseña una segunda prueba que discrimine entre las dos causas más probables.

Ejercicios

1. Señala source, transformaciones y sink en el caso guiado.
2. Explica qué evidencia refutaría la hipótesis.
3. Descompón la primera prueba documentada por opciones y argumentos.
4. Propón un control negativo y una mitigación causal.

Resumen

Estos privilegios saltan las ACL para leer/escribir cualquier fichero: volcas el SAM y sacas el hash del administrador. La técnica queda confirmada solo cuando una prueba mínima produce la evidencia prevista y descarta explicaciones alternativas.

Chuleta operativa

1. Confirmar alcance y condiciones.
2. Identificar entrada, componente y permisos.
3. Ejecutar prueba mínima y control.
4. Interpretar señal antes de escalar.

5. Guardar evidencia y mitigación.

Referencias

- [Concepto fuente de THM Fieldbook](#) (sebackup-serestore)
- [Referencia técnica externa](#)

Navegación

Anterior: [Construcción de payloads](#). Índice: [curso](#). Ejercicios y chuleta se enlazarán desde la matriz de trazabilidad.